

# CompTIA SecAI+ Certification

## Section 6 – Governance, Risk, and Compliance

### Official Study Notes (Downloadable)

---

#### Section Overview

Section 6 focuses on **governance, risk management, compliance, and ethical responsibility** for AI systems. While this section is less technical than attack and defense domains, it is critically important for decision-making, leadership alignment, regulatory compliance, and long-term organizational trust.

CompTIA places strong emphasis on **judgment, accountability, and risk-based thinking** in this domain. Many questions assess your ability to select the *most appropriate action* from a governance or compliance perspective rather than a purely technical response.

This section prepares you to:

- Apply governance frameworks to AI systems
- Assess and manage AI-related risk
- Support regulatory and compliance requirements
- Understand ethical responsibilities in AI deployment

---

#### AI Governance Fundamentals

AI governance refers to the structures, policies, roles, and processes used to ensure AI systems are developed and operated responsibly.

Core governance objectives:

- Accountability for AI decisions
- Transparency and explainability
- Alignment with organizational values
- Oversight of AI lifecycle activities

Effective governance ensures AI systems remain aligned with business, legal, and ethical expectations.

---

#### Roles and Responsibilities

Clear ownership is essential for AI governance.

Common AI governance roles:

- Executive sponsors
- AI system owners
- Data stewards
- Security and risk teams
- Compliance and legal teams

Lack of defined responsibility is a common cause of AI governance failure.

---

## AI Risk Management

AI risk management focuses on identifying, assessing, and mitigating risks introduced by AI systems.

Key risk categories: - Security risk - Privacy risk - Operational risk - Reputational risk - Legal and regulatory risk

AI risks evolve over time and must be reassessed continuously.

---

## Risk Assessment and Impact Analysis

Risk assessment involves: - Identifying threats and vulnerabilities - Estimating likelihood and impact - Prioritizing mitigation efforts

Impact analysis should consider: - Harm to individuals - Business disruption - Regulatory penalties - Loss of trust

Not all AI risks can be eliminated; many must be managed.

---

## Responsible AI Principles

Responsible AI emphasizes ethical use of AI technologies.

Common principles: - Fairness and non-discrimination - Transparency and explainability - Accountability - Human oversight - Reliability and safety

Security professionals play a key role in enforcing responsible AI practices.

---

## Bias and Fairness Risks

Bias can arise from: - Skewed training data - Historical inequalities - Model design choices

Security impact: - Unequal enforcement - Discriminatory outcomes - Legal exposure

Mitigation requires governance, testing, and monitoring.

---

## Transparency and Explainability

Explainability refers to the ability to understand how AI systems make decisions.

Why explainability matters: - Regulatory requirements - Incident investigation - User trust

Highly opaque models require additional oversight and documentation.

---

## **Privacy and Data Protection**

AI systems often process sensitive data.

Privacy considerations: - Data minimization - Purpose limitation - Consent and lawful processing - Retention controls

Privacy risks extend across the AI lifecycle, including training and inference.

---

## **Regulatory and Compliance Landscape**

AI regulation is expanding globally.

Key compliance drivers: - Data protection regulations - Industry-specific rules - Emerging AI-specific laws

Organizations must track regulatory developments affecting AI systems.

---

## **Standards and Frameworks**

Common frameworks referenced in AI governance: - NIST AI Risk Management Framework - ISO standards related to AI and security - Organizational governance models

Frameworks provide structured guidance but require adaptation to context.

---

## **Third-Party and Supply Chain Governance**

AI systems rely on external vendors.

Governance controls include: - Vendor risk assessments - Contractual security requirements - Ongoing monitoring

Third-party failures can create compliance and security exposure.

---

## Auditing and Accountability

Auditing supports governance by: - Verifying compliance - Detecting control gaps - Supporting regulatory inquiries

Auditability must be designed into AI systems.

---

## Ethics vs Compliance

Compliance meets legal requirements.

Ethics goes beyond compliance to consider: - Social impact - Long-term consequences - Human dignity

Security professionals must support both.

---

## Exam Keywords to Watch For

- Governance framework
  - Accountability
  - Risk assessment
  - Responsible AI
  - Explainability
  - Compliance obligation
  - Third-party risk
- 

## Rapid Revision Summary

- Governance defines oversight and accountability
  - AI risk spans security, privacy, and ethics
  - Compliance requirements continue to evolve
  - Explainability supports trust and investigation
  - Bias and fairness require active management
  - Governance is continuous, not one-time
- 

**End of Section 6 – Study Notes**